

Políticas IAM

Princípio do Menor Privilégio

AWS Certified Developer Associate

Instrutor: Marlon Anesi

O que são IAM Policies?

Documentos JSON que definem permissões

Especificam o que uma identidade pode ou não pode fazer

```
{
  "Version": "2012-10-17",
  "Statement": [
    {
      "Effect": "Allow",
      "Action": "s3:GetObject",
      "Resource": "arn:aws:s3:::my-bucket/*"
    }
  ]
}
```

Anatomia de uma IAM Policy

Elemento	Descrição	Exemplo
Version	Versão da linguagem (sempre 2012-10-17)	"2012-10-17"
Effect	Allow ou Deny	"Allow"
Action	Ações permitidas/negadas	"s3:GetObject"
Resource	ARN dos recursos afetados	"arn:aws:s3:::bucket/*"
Condition	Condições opcionais	"IpAddress": {...}
Principal	Quem pode assumir (resource-based)	"AWS": "arn:aws:iam::..."

Tipos de IAM Policies

AWS Managed

- Criadas pela AWS
- Prefixo: aws/
- Não editáveis
- Ex: ReadOnlyAccess

Customer Managed

- Criadas por você
- Reutilizáveis
- Versionamento
- Recomendadas!

Inline

- Anexadas diretamente
- 1:1 com entidade
- Sem reutilização
- Evitar quando possível

DICA: Prefira Customer Managed Policies para reutilização e controle de versões!

Princípio do Menor Privilégio

"Conceda apenas as permissões necessárias para executar uma tarefa"

NÃO FAÇA:

```
"Action": "*"
"Resource": "*"

```

Permissão total!
Risco de segurança!

FAÇA:

```
"Action": ["s3:GetObject",
           "s3:PutObject"]
"Resource": "bucket/prefix/*"

```

Permissões específicas!

Como aplicar:

1. Comece sem permissões e adicione conforme necessário
2. Use IAM Access Analyzer para identificar permissões não usadas
3. Revise periodicamente e remova permissões desnecessárias

Lógica de Avaliação de Políticas

Ordem de avaliação (muito importante no exame!):

1

Explicit Deny?

SIM = DENIED

2

Allow explícito?

SIM = ALLOWED

3

Nenhum match?

= DENIED (default)

REGRA DE OURO: Explicit Deny SEMPRE vence! Se houver um Deny, nenhum Allow pode sobrescrevê-lo.

Pontos-chave para o Exame

1. Estrutura de Policy

- Effect, Action, Resource são obrigatórios
- Principal apenas em resource-based policies

2. Tipos de Policies (frequente!)

- AWS Managed: criadas pela AWS, não editáveis
- Customer Managed: reutilizáveis, versionadas
- Inline: anexadas diretamente, evitar

3. Avaliação de Policies

- Explicit Deny SEMPRE ganha
- Sem match = Implicit Deny (padrão)

LEMBRE-SE: Se tem Deny explícito na policy > SEMPRE será negado, não importa quantos Allows existam!